



Beatriz Falasca (RM 570086)
Felipe Lessa (RM 570626)
Gabriel Rodrigues (RM 568762)
Gabrielle Trindade (RM 569092)
Maria Eduarda Rodrigues (RM 572951)

Sprint 3

Plano de Projeto de Solução

Data ethics, governance & security in the AI age

Curso: Data Science - Turma: 1TSCPF

Docente: Ricardo Selas

1. INTRODUÇÃO	3
2. ANÁLISE DO DESAFIO	3
2.1. DADOS A SEREM UTILIZADOS	3
2.2. ELICITAÇÃO E CLASSIFICAÇÃO DOS REQUISITOS	3
2.3 GAPS IDENTIFICADOS	4
2.3.1 DECISÃO MANUAL LENTA	4
2.3.2 VIÉS POTENCIAL NA DECISÃO INDIVIDUAL	4
2.3.3 VIÉS HERDADO DE DADOS DE TREINAMENTO	4
2.3.4 QUESTÕES LGPD E SEGURANÇA DA INFORMAÇÃO	4
2.3.5 AUSÊNCIA DE “DONO DE DADO”	5
2.4. JUSTIFICATIVA DA SOLUÇÃO DE IA ÉTICA	5
3. SOLUÇÃO INOVADORA	5
3.1. ARQUITETURA DA SOLUÇÃO (TOGAF-ADM)	5
3.2. SELECT AI	5
3.3. CAMADA DE QUALIDADE DE DADOS DO OES/DES	6
3.4. ÉTICA, LGPD, AUDITORIA E SEGURANÇA	6
3.4.1 GOVERNANÇA DO DADO DE TREINAMENTO	7
4. APLICAÇÃO COBIT E MÉTODO	7
4.1 MAPEAMENTO	7
4.2 PAPÉIS DE GOVERNANÇA	7
4.3 FLUXOGRAMA DO CICLO DE DADOS	8
4.4 MÉTODO DE IMPLEMENTAÇÃO	8
5. EXERCÍCIOS/SIMULAÇÕES	9
5.1 CENÁRIO 1: SOBRECARGA HOSPITALAR COM REALOCAÇÃO OES/DES	9
5.2 CENÁRIO 2: QUERY EM LINGUAGEM NATURAL COM INSIGHT ÉTICO E LGPD	9
6. ENCERRAMENTO	9

1. INTRODUÇÃO

A disciplina Data Ethics, Governance & Security in the AI Age propõe o desafio de projetar soluções analíticas que integrem inteligência artificial à gestão hospitalar de forma ética, segura e auditável. Nesta Sprint 3, nossa equipe avança sobre o projeto DataCross, apresentado nos Sprints 1 e 2, incorporando ao Sistema de Suporte à Decisão Clínica (CDSS) já desenvolvido a camada formal de governança e ética prevista no desafio: o Oracle Ethics Shield (OES).

Aplicamos o OES ao escopo específico do nosso projeto sob a denominação DataCross Ethics Shield (DES), a implementação particular do OES dentro da solução DataCross, mantendo plena aderência conceitual ao que foi solicitado no enunciado, mas com identidade própria consistente com o produto que vimos desenvolvendo desde o Sprint 1. Ao longo deste documento, os termos OES e DES são usados de forma intercambiável: OES designa o conceito/entregável exigido pelo desafio Oracle/FIAP; DES designa sua materialização concreta no DataCross.

Enquanto o enunciado da Sprint 3 descreve um painel de acesso hospitalar populacional (fontes SIH/SUS, CNES, CSV), o DataCross opera em nível individual/clínico: leitura de prontuários eletrônicos via Oracle FHIR, aplicação de NLP e um motor de scoring para sugerir elegibilidade de alta ou transferência, sempre com validação humana obrigatória do médico regulador. Essa adaptação foi deliberada: em vez de recomeçar o projeto do zero para simular fontes de dados genéricas, optamos por aprofundar a governança e a ética sobre a solução real que já vínhamos construindo, o que acreditamos gerar uma entrega mais consistente e verificável.

Nesta sprint, o objetivo é demonstrar que o DataCross não é apenas tecnicamente funcional, mas também governado desde a concepção, aplicando princípios de Requisitos, Governança de TI/Dados, COBIT 2019, Qualidade de Dados e Arquitetura Empresarial (TOGAF-ADM), conforme desenvolvido ao longo da disciplina.

2. ANÁLISE DO DESAFIO

2.1. DADOS A SEREM UTILIZADOS

O DataCross opera com duas camadas de dados distintas e complementares:

(a) Dados públicos de treinamento e calibração, bases epidemiológicas e administrativas de acesso público (SIH/SUS, DATASUS/TabNet, CNES) foram utilizadas para treinar e calibrar o motor de scoring e o módulo de NLP do OES/DES. Esses dados fundamentam os protocolos clínicos de referência e permitem que o Select AI compreenda e responda corretamente a consultas em linguagem natural sobre padrões populacionais de internação.

(b) Dados individuais de prontuário (inferência), extraídos em tempo real ou batch dos sistemas hospitalares (MV, Tasy, Soul MV) via Oracle FHIR, convertidos em JSON e processados pelo motor de scoring para gerar a recomendação de alta/transferência de cada paciente específico.

Essa separação é central para a governança do projeto: os dados de treinamento, por serem públicos e agregados, têm regime de tratamento mais permissivo, porém os dados de inferência são dados sensíveis de saúde na forma da LGPD (Art. 5º, II) e exigem os controles de anonimização, criptografia e auditoria descritos na seção 3.4.

2.2. ELICITAÇÃO E CLASSIFICAÇÃO DOS REQUISITOS

Aplicando a metodologia de elicitação de requisitos estudada na disciplina, organizamos as necessidades do DataCross nos três níveis clássicos:

Nível	Requisito do DataCross
-------	------------------------

Negócio	Reduzir o tempo médio de decisão de alta/transferência hospitalar e o custo evitável por internação prolongada sem necessidade clínica.
Usuário	O médico regulador precisa visualizar, em um único painel, o score de elegibilidade do paciente com os fatores clínicos que o justificam, podendo aprovar, contestar ou redirecionar a sugestão da IA.
Sistema	O sistema deve processar o prontuário via NLP (OCI Language), aplicar o motor de scoring ponderado e classificar o paciente em uma das três faixas (Apto/Reavaliar/Manter internado) em tempo hábil, com trilha de auditoria completa.

Classificando ainda os requisitos de sistema entre funcionais (calcular score, gerar dashboard, registrar validação médica) e não-funcionais (tempo de resposta, criptografia de dados sensíveis, usabilidade da interface para o médico regulador), garantimos que a solução atenda tanto ao "o que faz" quanto ao "como deve ser", evitando um dos principais motivos de falha em projetos de dados: requisitos mal definidos.

2.3 GAPS IDENTIFICADOS

2.3.1 DECISÃO MANUAL LENTA

O processo tradicional de avaliação de alta/transferência depende de análise manual e individual dos prontuários pelo corpo médico regulador, gerando os índices de excesso de permanência já quantificados no Sprint 2.

2.3.2 VIÉS POTENCIAL NA DECISÃO INDIVIDUAL

Decisões clínicas tomadas sob pressão de tempo e sobrecarga de leitos podem introduzir viés não intencional na priorização de pacientes, sem rastreabilidade dos critérios usados.

2.3.3 VIÉS HERDADO DE DADOS DE TREINAMENTO

Por serem calibrados sobre bases públicas de uma região e período específicos, os protocolos e o motor de scoring podem carregar viés geográfico, socioeconômico ou de subnotificação presente nos dados históricos de origem, um risco que precisa ser monitorado e mitigado continuamente, não apenas resolvido uma vez no treinamento inicial.

2.3.4 QUESTÕES LGPD E SEGURANÇA DA INFORMAÇÃO

Prontuários eletrônicos contêm dados sensíveis de saúde (Art. 5º, II, LGPD), exigindo controles de anonimização, criptografia e auditoria que, em processos manuais, raramente são formalizados de ponta a ponta.

2.3.5 AUSÊNCIA DE “DONO DE DADO”

Não há, no processo tradicional, uma distinção clara entre quem opera o processo assistencial (Dono do Processo) e quem responde pela integridade e conformidade do dado clínico (Dono do Dado), lacuna que a Sprint 3 corrige (ver seção 4.2).

2.4. JUSTIFICATIVA DA SOLUÇÃO DE IA ÉTICA

Dados do setor (IBM Institute for Business Value, 2026) mostram que 86% das empresas já utilizam IA operacionalmente, mas 87% dos líderes apontam segurança como principal desafio de adoção, além disso, apenas 5% relatam ROI financeiro claramente mensurável, evidenciando que a lacuna não está na capacidade técnica da IA, mas na ausência de governança que sustente sua confiabilidade. Para secretarias de saúde e redes hospitalares, isso se traduz em um risco duplo: adotar IA sem governança expõe a organização a vieses e não conformidade, mas não adotar IA mantém a ineficiência operacional documentada na análise de casos clínicos. O Oracle Ethics Shield, implementado como DataCross Ethics Shield (OES/DES), é a resposta a esse dilema, permitindo que a IA opere com velocidade, mas dentro de trilhos éticos e auditáveis.

3. SOLUÇÃO INOVADORA

3.1. ARQUITETURA DA SOLUÇÃO (TOGAF-ADM)

Para sustentar a arquitetura já desenvolvida no Sprint 2, reorganizamos sua descrição segundo três fases do ciclo TOGAF-ADM, framework de arquitetura empresarial estudado na disciplina:

- Fase B: Arquitetura de Negócio

Define o "porquê" da solução: a estratégia é reduzir o tempo de decisão de alta/transferência e o custo evitável por permanência prolongada. A governança do processo estabelece papéis claros, o Médico Regulador como validador final de toda decisão clínica (nenhuma decisão é efetivada sem validação humana) e o time DataCross como responsável técnico pela plataforma. O processo mapeado de ponta a ponta é: prontuário eletrônico → extração → processamento por IA → validação médica → registro no SIRESP.

- Fase C: Arquitetura de Sistemas de Informação

Compreende dois componentes integrados, já implementados no protótipo:

Arquitetura de Dados: Oracle Autonomous Database como repositório central, combinando dados relacionais (cadastros e validações) e não estruturados (textos clínicos e resultados JSON da IA) em um único engine, eliminando a necessidade de um banco de documentos separado.

Arquitetura de Aplicações: Oracle FHIR + OCI Functions para extração; OCI Language para NLP; Oracle APEX como front-end low-code, com dois portais distintos para os dois perfis de usuário (Médico Regulador e, futuramente, gestor hospitalar).

- Fase D: Arquitetura de Tecnologia

A infraestrutura que sustenta a solução: Oracle Cloud Infrastructure (OCI) hospedando o Object Storage (zona de pouso intermediária, tolerante a falhas), as OCI Functions (processamento serverless) e o Autonomous Database. Essa camada garante escalabilidade e elimina a necessidade de infraestrutura própria por parte das redes hospitalares.

O fluxo unidirecional completo (prontuário → FHIR → Object Storage → OCI Function/IA → Autonomous DB → API → APEX → Médico Regulador → SIRESP), com as nove etapas já documentadas no Sprint 2, permanece a espinha técnica da solução, agora enquadrado formalmente dentro dessas três fases.

3.2. SELECT AI

Como evolução para a Sprint 3, propomos a incorporação do Select AI da Oracle ao painel, permitindo que o médico regulador ou gestor hospitalar faça perguntas em linguagem natural diretamente sobre a base de dados, sem necessidade de conhecimento em SQL. Exemplos de queries que o Select AI deve suportar:

- "Quanto pacientes com diagnóstico de AVC estão aptos à alta hoje?"
- "Qual o tempo médio de internação por infecção urinária no último mês?"
- "Liste os pacientes com score abaixo de 40 que estão internados há mais de 10 dias."

O Select AI converte a pergunta em SQL, executa a consulta no Oracle Autonomous Database e retorna o resultado em linguagem natural, sempre respeitando as mesmas políticas de controle de acesso (Oracle IAM) já aplicadas ao restante do painel, de modo que a conveniência da linguagem natural não crie um atalho para acesso indevido a dados sensíveis.

3.3. CAMADA DE QUALIDADE DE DADOS DO OES/DES

Um pilar frequentemente negligenciado em soluções de IA em saúde é a qualidade do dado de entrada, resumida no princípio GIGO (Garbage In, Garbage Out): se o prontuário eletrônico contém informação incompleta, inconsistente ou desatualizada, o motor de scoring herda esse erro e propaga uma recomendação clínica potencialmente incorreta. Para mitigar esse risco, o OES/DES incorpora uma etapa de Data Profiling anterior à aplicação do NLP:

- Profiling: diagnóstico automático da estrutura do prontuário recebido (campos obrigatórios preenchidos, tipos de dados corretos, formatos padronizados).
- Análise: identificação de padrões e anomalias (ex.: datas de internação inconsistentes, campos de diagnóstico vazios).
- Limpeza: padronização, correção e, quando aplicável, imputação de valores ausentes segundo regras clínicas pré-definidas, antes de o prontuário seguir para o motor de scoring.

Esse fluxo alimenta um indicador quantitativo, o DQI (Data Quality Index), calculado como a média ponderada das dimensões de completude, unicidade e validade de cada prontuário processado. O DQI é exibido no dashboard do médico regulador como um selo de confiabilidade ao lado do score de elegibilidade: um prontuário com DQI baixo sinaliza que a recomendação da IA deve ser tratada com mais cautela, reforçando a transparência do sistema perante o validador humano.

3.4. ÉTICA, LGPD, AUDITORIA E SEGURANÇA

Mitigação de vieses: o motor de scoring é auditável por desenho, separa os fatos clínicos extraídos da lógica de pontuação, permitindo que o médico entenda exatamente por que a IA sugeriu determinada classificação (ex.: cruzamento com protocolos do PCDT/MS), evitando o efeito "caixa-preta".

Conformidade LGPD: anonimização na origem (hash SHA-256 substituindo CPF antes de qualquer transmissão), isolamento por hospital (OCI Compartment dedicado com IAM policies), criptografia em repouso (TDE) e em trânsito (TLS 1.3), controle de acesso via APEX + OCI Identity Domains com papéis distintos para MÉDICO e REGULADOR, e minimização de dados (apenas campos necessários à decisão são processados), mapeados artigo a artigo contra a Lei 13.709/2018.

Auditoria: OCI Data Safe monitora e registra todos os acessos ao banco de dados, atendendo ao Art. 37 da LGPD. Como evolução proposta para esta sprint, sugerimos um log de auditoria imutável (estilo blockchain/hash-chain) sobre os registros de validação médica, de modo que nenhuma decisão clínica registrada no sistema possa ser alterada retroativamente sem deixar rastro.

3.4.1 GOVERNANÇA DO DADO DE TREINAMENTO

Diferentemente da mitigação de viés algorítmico (que atua sobre a lógica de pontuação, já descrita), a mitigação de viés de origem exige auditoria periódica da representatividade dos dados públicos usados na calibração do modelo, verificando se os protocolos aprendidos permanecem válidos à medida que o DataCross é aplicado a novas regiões ou períodos. Propomos que essa auditoria seja formalizada como uma rotina do OES/DES, com retreinamento ou recalibração do motor de scoring sempre que a distribuição dos dados de treinamento se afastar significativamente da população efetivamente atendida, prática alinhada ao princípio de accountability da LGPD (Art. 6º, X) e à recomendação de monitoramento contínuo da Fase G do TOGAF-ADM (Governança da Implementação).

4. APLICAÇÃO COBIT E MÉTODO

4.1 MAPEAMENTO

Objetivo COBIT 2019	Descrição	Funcionalidades OES/DES/Painel
APO12 — Gerenciar Riscos	Gerenciar riscos de TI, incluindo segurança e conformidade	Motor de scoring auditável (mitigação de viés algorítmico e de viés herdado dos dados de treinamento), monitoramento de acesso a dados sensíveis via OCI IAM
DSS05 — Gerenciar Segurança	Garantir a segurança dos sistemas de informação e dos dados	Criptografia TDE/TLS 1.3, controle de acesso Zero-Trust, registro de auditoria via OCI Data Safe (evolução: log imutável)
MEA01 — Monitorar, Avaliar e Analisar Desempenho e Conformidade	Monitorar desempenho de processos de TI e conformidade regulatória	Dashboard de conformidade LGPD, DQI (Data Quality Index), taxa de aprovação médica, métricas de tempo de decisão

4.2 PAPÉIS DE GOVERNANÇA

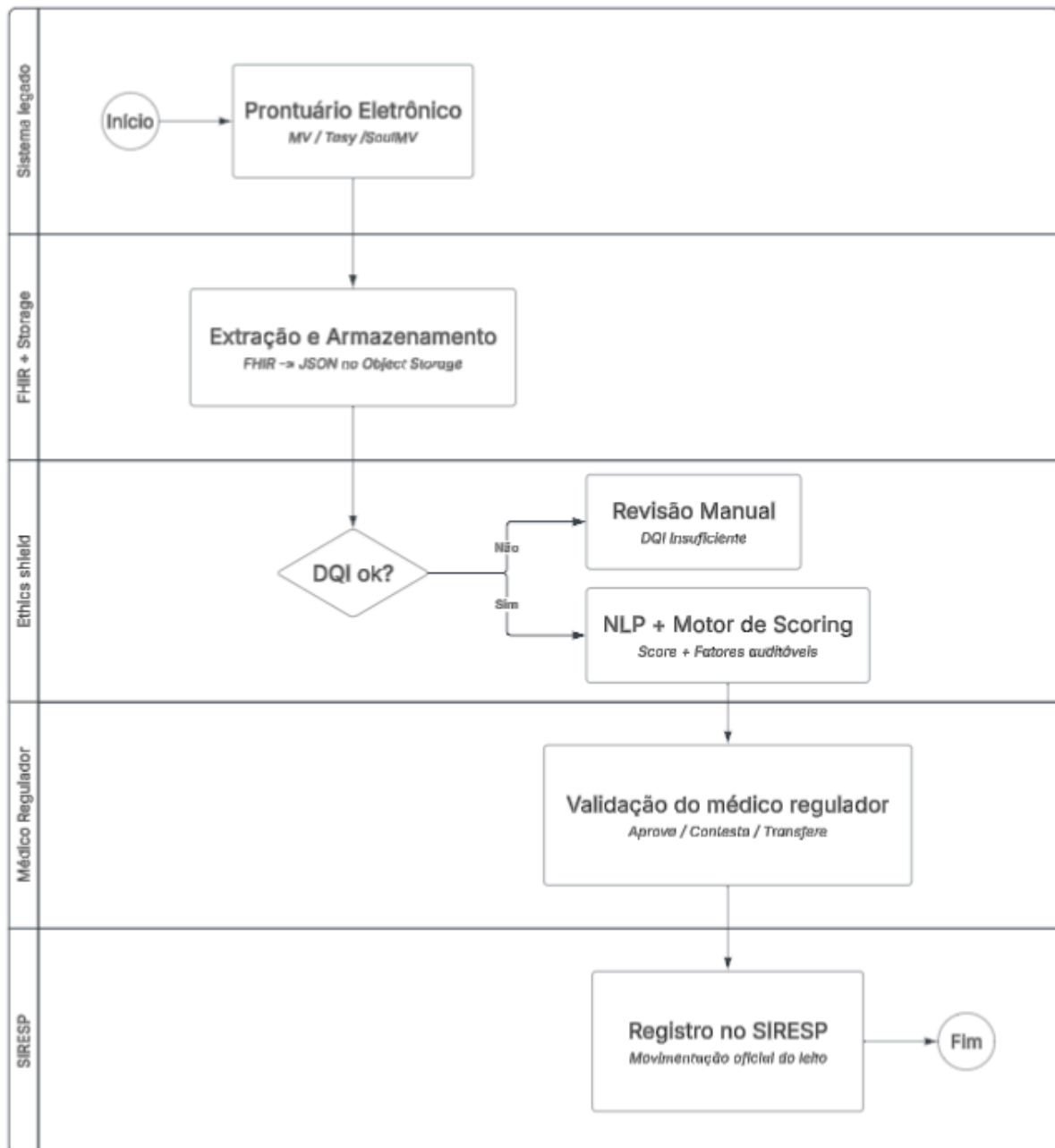
Formalizando uma distinção central em governança de dados aplicada ao BPM:

- Dono do Processo (Process Owner): a equipe DataCross / gestão hospitalar de TI, responsável pelo desempenho de ponta a ponta do fluxo (eficiência do pipeline, tempo de resposta, SLA de disponibilidade do painel).
- Dono do Dado (Data Owner): o corpo médico regulador, em última instância, a secretaria de saúde/hospital, responsável pela autoridade decisória sobre o ativo "prontuário clínico", quem pode visualizar, qual o padrão de qualidade exigido e a conformidade legal do seu uso.

Essa distinção resolve a pergunta central de governança levantada na disciplina: "como garantir que o dado gerado no Processo A (extração do prontuário) tenha a qualidade exigida pelo Dono do Dado para o Processo B (decisão clínica)?", respondida no DataCross pela camada de Data Profiling descrita na seção 3.3.

4.3 FLUXOGRAMA DO CICLO DE DADOS

Representação do processo em notação BPMN, organizada em raias (swimlanes) por ator, com evento de início e evento de fim formalmente identificados, evoluindo o fluxograma unidirecional do Sprint 2 para uma visão de papéis.



4.4 MÉTODO DE IMPLEMENTAÇÃO

Seguindo o ciclo iterativo do TOGAF-ADM, a implementação do OES/DES está planejada em fases:

(1) Consolidação da Fase C: motor de scoring e integração NLP, atualmente em finalização de mapeamento técnico conforme relatado no Sprint 2;

(2) Fase E (Oportunidades e Soluções): decisão de build vs. buy para o módulo de auditoria imutável;

(3) Fase F (Planejamento de Migração): roadmap de evolução da Opção 1 (carga JSON batch) para a Opção 2 (API REST/FHIR em tempo real), já identificada como diferencial futuro no Sprint 2;

(4) Fase G (Governança da Implementação): monitoramento contínuo de conformidade com a arquitetura aprovada, evitando desvios não documentados, incluindo a auditoria periódica de representatividade dos dados de treinamento (seção 3.4).

5. EXERCÍCIOS/SIMULAÇÕES

5.1 CENÁRIO 1: SOBRECARGA HOSPITALAR COM REALOCAÇÃO OES/DES

Situação: Um hospital da rede atinge 95% de ocupação de leitos clínicos. O gestor aciona o painel DataCross para identificar pacientes elegíveis à alta ou transferência.

Simulação: O Select AI recebe a query "Liste pacientes com AVC, ITU ou Pneumonia com score de transferência acima de 70, ordenados por tempo de internação decrescente." O sistema retorna, por exemplo, um paciente internado há 12 dias com diagnóstico de ITU e score 83 (classificação "Apto para transferência/alta/reabilitação"). O prontuário é exibido ao Médico Regulador com os fatores auditáveis (ex.: ausência de febre há 48h, exames laboratoriais dentro do padrão NEWS2). O médico confirma a alta; o sistema registra a decisão e comunica ao SIRESP, liberando o leito.

5.2 CENÁRIO 2: QUERY EM LINGUAGEM NATURAL COM INSIGHT ÉTICO E LGPD

Situação: Um gestor da secretaria de saúde deseja entender o desempenho da rede sem acessar dados individualizados de pacientes.

Simulação: Query: "Qual a taxa de aprovação das sugestões da IA pelos médicos reguladores no último trimestre?" O Select AI traduz a pergunta em SQL agregada (sem retornar CPF, nome ou qualquer identificador individual, apenas contagens e percentuais), respeitando o princípio de minimização de dados da LGPD. O resultado retorna, por exemplo, "64% de taxa de aprovação", permitindo à gestão avaliar a confiabilidade do modelo sem expor dados sensíveis de nenhum paciente específico, demonstrando que insights estratégicos e conformidade legal não são mutuamente excludentes.

6. ENCERRAMENTO

O Oracle Ethics Shield, implementado como DataCross Ethics Shield (OES/DES), demonstra que é possível conciliar velocidade de decisão clínica com rigor ético e conformidade regulatória. Ao longo desta sprint, consolidamos uma solução que reduz o tempo de avaliação de elegibilidade para alta ou transferência hospitalar por meio da triagem automática via NLP, sem abrir mão da supervisão humana em nenhuma etapa do processo. Essa agilidade não veio à custa da transparência: o motor de scoring permanece auditável por desenho, expondo ao médico validador os fatores clínicos que fundamentam cada recomendação, enquanto a auditoria periódica da representatividade dos dados de treinamento garante que nenhuma decisão seja uma caixa-preta, nem em nível individual, nem na origem do próprio modelo.

Do ponto de vista regulatório, a solução cobre de forma completa os controles de privacidade exigidos pela LGPD, combinando anonimização, criptografia, auditoria de acessos e minimização de dados em conformidade com os artigos da lei mapeados ao

longo do documento. Essa conformidade é reforçada por uma camada de qualidade de dados que passou a existir apenas nesta sprint: a introdução do DQI como métrica contínua de confiabilidade do prontuário processado evita que o princípio do GIGO comprometa a qualidade das recomendações geradas pela IA, tornando a governança do dado tão rigorosa quanto a governança da decisão clínica.

Em termos de impacto para o negócio, os números já levantados no Sprint 2 continuam servindo de referência concreta para o retorno esperado da solução: o potencial de custo evitável de R\$ 9,8 milhões por ano, calculado sobre as três condições clínicas piloto, ilustra de forma tangível o Retorno sobre Investimento que redes hospitalares podem esperar ao adotar o DataCross em escala. Como próximos passos, a equipe seguirá priorizando a construção do MVP, com foco na integração do OCI Language aos scripts Python do motor de scoring, além da formalização do log de auditoria imutável como evolução natural da camada de segurança do OES/DES.